LABORATUVAR FÖYÜ 3

Tehdit Senaryoları ve Risk Değerlendirmesi

3. hafta

Saldırı yüzeyi · senaryo zinciri · L × S × E puanlama · önlem önerileri

Makine	Baromak LUNA 1300 PRO Otomatik Fırça Zımpara Makinesi
Hazırlayan	Muhammed Cemil Caka

1. Amaç

LUNA 1300 PRO'ya yönelik siber tehditleri, zincirin sonunda insana ne olduğunu gösterecek şekilde senaryolaştırmak, bunları puanlayıp önceliklendirmek ve her biri için önlem önermek.

2. Yöntem

Her senaryoyu beş adımda yazdım: **kim → hangi kapıdan → ne yapıyor → zincir → fiziksel sonuç.** Puanlamada L (olasılık), S (şiddet) ve E (maruziyet) için 1–3 arası değer verdim, skor = L × S × E. Aralıklar: 18–27 kritik, 9–17 yüksek, 4–8 orta, 1–3 düşük.

İki kurala dikkat ettim. Birincisi, S=3 olan bir senaryo skoru ne olursa olsun ilk sıralara alınıyor. İkincisi, zincir "veri çalındı" diye bitiyorsa bu emniyet senaryosu sayılmıyor; bir adım daha ilerletip makinenin başındaki insana ne olduğunu yazmak gerekiyor.

3. Saldırı Yüzeyi

Tablo 1. Makineye giden kapılar

Kapı	Neden açık	Ulaştığı bölge
G1 · Üreticinin uzak bağlantı modemi	7/24 açık; ortak servis parolası ihtimali	Z2
G2 · HMI dokunmatik ekran ve USB portu	Parola yok, herkes reçetelere erişebiliyor	Z2
G3 · Servis laptopu	Başka fabrikalara gidiyor, üzerinde safety yazılımı var	Z1 ve Z2
G4 · Ofis ağı	E-posta; ofis ile makine ağının ayrılmamış olma ihtimali	Z5 → Z2

4. Senaryolar

R1 Uzaktan duruş rampası değişikliği — L2 × S3 × E3 = 18 · Kritik

Kim	Dış saldırgan (sızmış ortak servis parolası)
Kapı	G1 · uzak bağlantı modemi
Ne yapıyor	HMI/PLC üzerinden fırça inverterlerinin duruş rampasını uzatıyor.
Zincir	Kapak kilidi sabit bir süre bekleyip açılıyor, fırça ise hâlâ dönüyor.
Fiziksel sonuç	Zımpara değiştiren bakımcının eli ya da kolu fırçaya kapılıyor.

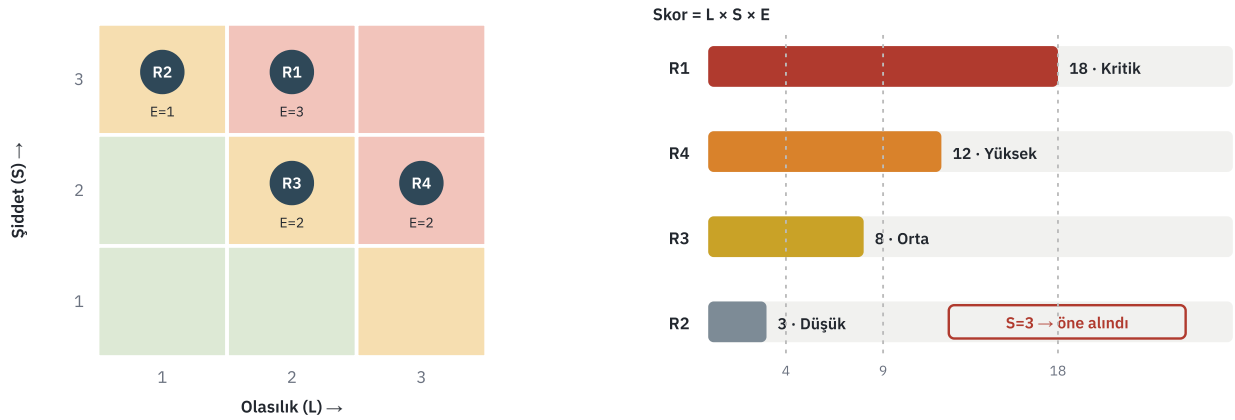
R2 Safety programının değiştirilmesi	L1 × S3 × E1 = 3 · Düşük
Kim	Zararlı yazılım bulaşmış servis laptopu
Kapı	G3 · servis laptopu
Ne yapıyor	Safety PLC'de kilit gecikmesini kısaltıyor ya da bir kapak girişini köprülüyor.
Zincir	Koruyucu açıkken makine çalışabiliyor.
Fiziksel sonuç	Dönen fırçaya doğrudan erişim, ağır yaralanma.

R3 Fidye yazılımı ve kaybolan reçeteler	L2 × S2 × E2 = 8 · Orta
Kim	Ofiste açılan bir e-posta eki
Kapı	G4 · ofis ağı
Ne yapıyor	Ayrılmamış ağ üzerinden HMI'ya ulaşıyor, ekranı kilitliyor, kayıtlı reçeteler kayboluyor.
Zincir	Operatörler baskı ayarlarını tahminen elle giriyor, fazla baskı veriliyor.
Fiziksel sonuç	İnce parça sıkışıp geri fırlıyor ve operatöre çarpıyor; aşırı sürtünmeden toz tutuşabiliyor.

R4 HMI'dan reçeteyle oynanması	L3 × S2 × E2 = 12 · Yüksek
Kim	Yetkisiz ya da dikkatsiz bir çalışan
Kapı	G2 · parolasız HMI
Ne yapıyor	Konveyör hızını en yükseğe (20 m/dk), baskı ayarını en alta çekiyor.
Zincir	Parçalar istasyonlarda takılıyor, operatör makine çalışırken sıkışan parçayı elle çıkarmaya çalışıyor.
Fiziksel sonuç	El giriş konveyöründe ya da fırçada sıkışıyor.

> **Not.** *R3'ü ilk yazdığımda "reçeteler şifrelendi" diye bitiriyordum. O hâliyle bir emniyet bulgusu olmadığı için zinciri operatöre ne olacağına kadar götürdüm.*

5. Puanlama ve Öncelik



Şekil 1. Senaryoların olasılık–şiddet matrisindeki yeri (solda) ve L × S × E skorları (sağda).

Tablo 2. Öncelik sırası

Sıra	Senaryo	L × S × E	Seviye	Not
1	R1 · Uzaktan duruş rampası değişikliği	2 × 3 × 3 = 18	Kritik	Bağlantı zaten var ve sürekli açık, bakımcı o çekmeceyi her vardiya açıyor.
2	R2 · Safety programının değiştirilmesi	1 × 3 × 1 = 3	Düşük	S=3 kuralıyla öne aldım.
3	R4 · HMI'dan reçeteyle oynanması	3 × 2 × 2 = 12	Yüksek	En olası senaryo ama sonucu genelde geri dönüşlü.
4	R3 · Fidye yazılımı	2 × 2 × 2 = 8	Orta	Üretim kaybı büyük, emniyet etkisi dolaylı.

R2'nin skoru düşük ama sonucu en ağır senaryo. Risk kaydında bu satırı kırmızı "S=3" işaretiyle tutacağım ki her revizyonda ilk bakılan satır olsun.

6. Önlem Önerileri

Tablo 3. Senaryolara karşı önerdiğim önlemler

Senaryo	Önlem	Bağlantılı föy
R1	Kapak kilidi sabit bir süreye değil, fırçanın durduğunun doğrulanmasına bağlanmalı; duruş rampası uzaktan yazılamamalı.	Föy 4
R2	Safety programının checksum'ı devreye almada kaydedilmeli ve her periyodik bakımda kontrol edilmeli; laptop/USB kuralı uygulanmalı.	Föy 2 (C1, laptop notu)
R4	HMI'da kullanıcı seviyeleri: operatör reçete seçebilir ama değiştiremez. Sıkışma için "önce durdur, sonra çekmeceyi aç" talimatı.	Föy 1 (SF-2)
R3	Ofis ve makine ağı ayrılmalı (C4), reçetelerin makine dışında yedeği tutulmalı.	Föy 2

7. Değerlendirme

Puanlamayı yaparken en olası senaryonun (R4) en tehlikeli senaryo olmadığını gördüm. R4 her gün olabilecek bir şey ama sonucu çoğunlukla geri dönüşlü; R1 ve R2 ise daha zor ama sonucu kalıcı yaralanma. S=3 kuralı olmasaydı R2 listenin en sonunda kalacaktı. R1'in kökü uzaktan bağlantı olduğu için gelecek haftaki güvenli uzak erişim tasarımının merkezine onu koyacağım.

8. Kaynaklar

1. LUNA 1300 PRO ilanı (TWM / AİMSAD): https://twm.com.tr/tr/ilan/luna-1300-pro-firca-zimpara-makinesi
2. Baromak ürün sayfası: https://baromak.com.tr/urun-detay.html?id=luna-1300-pro
3. Safety 4.0 Bootcamp laboratuvar föyleri (konu başlıkları için)
4. Föy 1 ve Föy 2 (bu çalışmanın önceki haftaları)